

Here is a comprehensive sample of a GRC (Governance, Risk, and Compliance) policy review. For this example, we will review a fictional **Data Classification and Protection Policy** for an organization transitioning to cloud infrastructure.

This template is structured to be presented to stakeholders, highlighting what works, what is missing, and the exact steps needed for remediation.

GRC Policy Review Document

Target Policy: Data Classification and Protection Policy (v1.2)

Project Scope: Cloud Infrastructure Migration Project

Review Date: July 9, 2026

Reviewer: Lead GRC Analyst GBPP Industries, LLC

1. Executive Summary

The purpose of this review is to evaluate the existing Data Classification and Protection Policy against the upcoming Cloud Infrastructure Migration. While the current policy provides a strong baseline for on-premise data handling, it lacks critical governance around cloud-native storage, third-party risk management, and recent updates to data privacy regulations. Immediate remediation is required before the cloud migration goes live.

2. Governance Assessment

Governance ensures that organizational goals align with security practices and that accountability is clearly defined.

- **Current State:** The policy successfully outlines data ownership for internal departments (e.g., HR, Finance) and establishes a clear data classification schema (Public, Internal, Confidential, Restricted).
- **Identified Weaknesses:** There is no documented Matrix of Responsibilities (RACI) for data hosted in external cloud environments. The policy assumes the internal IT team is solely responsible for data availability, ignoring the Shared Responsibility Model inherent in cloud computing.
- **Action Required:** Define specific roles for Cloud Security Architects and outline the exact security responsibilities owned by the Cloud Service Provider (CSP) versus internal staff.

3. Risk Management Assessment

Risk management evaluates how the policy identifies, mitigates, and monitors threats to the business.

- **Current State:** Acceptable risk thresholds are defined for physical media and internal server access. Data encryption standards (AES-256) are mandated for data at rest.
- **Identified Weaknesses:** The policy fails to address risks specific to cloud environments, such as misconfigured S3 buckets, compromised API keys, or insider threats at the CSP level. Furthermore, it lacks a defined process for continuous risk monitoring.
- **Action Required:** Integrate a Cloud Risk Assessment requirement into the policy. Mandate regular automated scanning for cloud misconfigurations and define the acceptable risk appetite for multi-tenant data hosting.

4. Compliance Alignment

Compliance ensures the policy meets legal, regulatory, and contractual obligations.

- **Current State:** The policy correctly references HIPAA requirements for patient data and PCI-DSS for payment information.
- **Identified Weaknesses:** The policy references outdated frameworks. It does not account for the cross-border data transfer restrictions outlined in the GDPR or the updated controls in NIST CSF 2.0.
- **Action Required:** Update regulatory cross-references. Add a mandatory compliance check for data residency requirements before migrating any Confidential or Restricted data to cloud regions outside the host country.

Gap Analysis & Remediation Plan

The following table prioritizes the findings to guide the security team's update schedule:

Gap Description	GRC Pillar	Severity	Recommended Remediation
Missing Shared Responsibility definitions	Governance	High	Add a "Cloud Environments" section detailing the CSP Shared Responsibility Model.
No cross-border data transfer rules	Compliance	High	Require Legal/GRC sign-off for cloud regions outside the primary jurisdiction.
Lack of cloud misconfiguration risks	Risk	Medium	Mandate automated Cloud Security Posture Management (CSPM) tools.
Outdated regulatory frameworks	Compliance	Low	Update references to NIST CSF 2.0 and current ISO 27001:2022 standards.

Sign-off and Next Steps

The policy requires a major revision (v2.0) to adequately support the Cloud Infrastructure Migration Project. The GRC team will draft the necessary amendments and submit the updated policy to the Information Security Steering Committee by August 1st for final approval.